

Reporte Ejecutivo de Gestión de Riesgos

Dirigido al Directorio — Clínica privada (120 empleados, 800 pacientes/día) | Preparado por: Responsable de Seguridad de la Información | Herramienta: SimpleRisk

Resumen ejecutivo

Tras la auditoría externa reciente, que identificó debilidades relevantes en nuestra gestión de riesgos, se relevó y evaluó formalmente el registro de riesgos de la clínica utilizando la metodología de Probabilidad × Impacto de SimpleRisk. Se identificaron **9 riesgos** específicos de nuestro contexto (historia clínica digital, facturación y datos de obras sociales), de los cuales **2 son de nivel Muy Alto y 7 de nivel Alto**. El denominador común de casi todos ellos es la ausencia histórica de controles formales: sin logging de accesos, sin capacitación en seguridad, sin backups verificados y sin generador de respaldo. Se proponen 3 planes de acción concretos, con responsable, plazo y presupuesto estimado, para atacar los riesgos de mayor severidad en los próximos meses. La inversión total propuesta es moderada frente al costo potencial de un incidente de exposición de datos de salud, que combina sanciones bajo la Ley 25.326, costos de contención y daño reputacional directo sobre la confianza de nuestros pacientes.

Top 5 riesgos por nivel

#	Riesgo	Categoría	P × I	Nivel
1	Acceso no autorizado a historia clínica	Confidencialidad	4 × 5 = 20	Muy alto
2	Phishing a personal administrativo	Operativo	5 × 4 = 20	Muy alto
3	Disponibilidad — caída temporal del sistema	Disponibilidad	4 × 4 = 16	Alto
4	Integridad de datos en historia clínica	Integridad	3 × 5 = 15	Alto
5	Pérdida de datos permanente	Integridad/Disp.	3 × 5 = 15	Alto

Estado de los planes de acción

Plan	Riesgo asociado	Responsable	Vencimiento	Presupuesto	Estado
RBAC + logging de accesos	Acceso no autorizado a HC	Jefe de Sistemas	15/12/2026	\$850.000	No iniciado
Anti-phishing + MFA	Phishing administrativo	Jefe de Sistemas / RRHH	30/11/2026	\$420.000	No iniciado
Generador + contingencia	Caída temporal del sistema	Jefe de Sistemas	28/02/2027	\$3.100.000	En cotización

Los 3 planes ya fueron cargados en SimpleRisk asociados a sus riesgos correspondientes. Ninguno se encuentra todavía en ejecución; se prioriza el plan de RBAC y logging por atacar el riesgo de mayor sensibilidad legal (datos de salud, Ley 25.326).

Recomendaciones prioritarias

Como marco general para explicar estos riesgos al Directorio, conviene pensar la amenaza externa como *el lobo feroz acechando a Caperucita Roja*: no siempre ataca de frente por la puerta principal, sino que busca el camino más corto y menos vigilado (un empleado que hace clic en un correo de phishing, una credencial de un ex-empleado que nunca se dio de baja). Ningún control aislado detiene a este atacante; como en *Los Tres Chanchitos*, la defensa tiene que construirse en **capas** — una casa de paja (solo usuario y contraseña) cae ante el primer soplo, mientras que controles superpuestos (RBAC, logging, MFA, backups verificados y generador de respaldo) son la "casa de ladrillos" que sí resiste.

Con ese marco, las prioridades concretas para los próximos 90 días son:

- Implementar RBAC y logging de accesos a la historia clínica electrónica (riesgo Muy Alto de mayor sensibilidad legal).
- Lanzar el programa de concientización anti-phishing y habilitar MFA en correo institucional y en el acceso al sistema HCE.
- Verificar y probar los backups existentes (política 3-2-1) antes de invertir en cualquier otro control — hoy no hay evidencia de que los backups actuales sean restaurables.

- Formalizar el checklist de baja de accesos (offboarding) de RRHH junto con Jefe de Sistemas.
- Por una cuestión elemental de continuidad física, y como recomendación prioritaria e inquebrantable de esta auditoría: **los centros de datos y racks de servidores nunca deben ubicarse junto a cocinas ni debajo de piletas, cisternas o baños**, dado el riesgo de incendio y de inundación, respectivamente, que ambas ubicaciones representan para la disponibilidad del sistema.

Quedamos a disposición del Directorio para presentar este reporte en mayor detalle y definir la asignación de presupuesto para los planes de acción propuestos.